

ASCII SMUGGLING CAMPAIGN HUNT

Defender XDR hunt for the source-observed finance-themed header domain and marketing-platform envelope pattern. This is not body-content detection.

HUNTING QUERY

CONFIDENCE: MEDIUM

REPORT DATE

5 September 2026

STATUS

Untested implementation sketch

PRIMARY TELEMETRY

Defender XDR / EmailEvents

OPERATIONAL VALUE

9.3 / 10

Campaign-specific behavioral infrastructure fingerprint. A match requires analyst validation.

CONTROLLED EIGHT-PAGE THREAT DOSSIER

FINANCE TOKEN CHAIN

3+ adjacent terms



em- / acems / emsd

followed by digits

HUNT • TRIAGE • TUNE

no body visibility in EmailEvents



EXECUTIVE ASSESSMENT

Decision-grade summary and evidence boundary.

ASSESSMENT

OPERATIONAL VALUE

9.3

Source-provided query, direct mail telemetry and a combined P2/P1 sender fingerprint suitable for retrospective hunting.

CLASSIFICATION

Campaign-specific behavior

Hunting query - Untested implementation sketch. It is precise enough to test, but mutable and not proven in the target environment.

- 2sender layers
- 30dsource query window
- 0body fields
- 1primary platform

Source fact

Microsoft observed finance-token header domains paired with envelope domains matching em-, acems or emsd plus digits.

Vendor interpretation

The sender pattern identifies campaign infrastructure while Unicode Tags disrupted some security parsing.

Assumptions

Defender for Office 365 populates both sender-domain fields and the local mail flow retains comparable messages.

Evidence boundary

EmailEvents does not expose the message body. This logic cannot observe U+E0020 or prove ASCII smuggling.



THREAT MECHANICS

Observed delivery behavior without extending the chain.

BEHAVIOR

01
Finance lure

High-volume inbound messages used finance-themed sender identities.
→

02
Tag insertion

Unicode Tags characters were placed inside visible finance words.
→

03
Parser divergence

Some filters tokenized content differently from the rendered message.

04
P2 pattern

Header domains concatenated at least three finance or brand tokens.
→

05
P1 pattern

Envelope domains followed operator naming shapes plus digits.
→

06
Layered defense

Microsoft reports most mail was caught by other protections.

Date / period	Source-supported observation
9 February 2026	Signature spike began.
~3 months	High-volume Unicode technique use.
After 15 May 2026	Sharp decline in the signature.
Through mid-June	Residual use; broader campaign continued without the technique.

ATT&CK

T1566 Phishing and T1027 Obfuscated Files or Information are directly supported by the reported behavior.



TELEMETRY & EVIDENCE MODEL

Minimum data contract and observability gaps.

TELEMETRY

REQUIRED

EmailEvents

Microsoft Defender for Office 365 telemetry in Defender XDR Advanced Hunting.

OPTIONAL ENRICHMENT

Raw MIME or message trace, EmailUrlInfo, threat verdicts, delivery state and campaign clustering.

Field	Reliability	Purpose
Timestamp	Documented	30-day source window
EmailDirection	Documented	Inbound scope
SenderFromDomain	Documented	P2 finance-token pattern
SenderMailFromDomain	Documented	P1 operator shape
NetworkMessageId	Documented	Message pivot
Delivery*, Threat*, Detection*	Documented	Triage context

Unavailable in EmailEvents

Message body and HTML, Unicode tag characters, rendering behavior, user interaction, credential submission and final compromise.

Coverage failure

No Defender for Office 365 deployment, incomplete P1/P2 fields, retention outside the activity period, or attacker infrastructure drift.



HUNTING LOGIC

Source-derived filters with no threshold or join.

KQL

HYPOTHESIS

If an attacker reuses the reported campaign infrastructure pattern, EmailEvents should show inbound mail whose header domain contains three adjacent finance tokens and whose envelope domain matches the operator naming shape. The combination, message disposition and sender context should distinguish it from ordinary financial marketing.

KQL - UNTESTED HUNT

```
let kwds = @"(capital|fund|hedge|express|solutions|choice|lend|growth|loan|loc|finance|business|pillar|advance|boost|catalyst|digital|direct|elevate|guardian|harbor|online|pulse|rocket|rush|united|wave|way|surge|swift|elite)";
EmailEvents
| where Timestamp > ago(30d)
| where EmailDirection == "Inbound"
| where SenderFromDomain matches regex strcat("(?i)", kwds, kwds, kwds)
| where SenderMailFromDomain matches regex @"(?i)(em-|acems|emsd)\d"
| project Timestamp, NetworkMessageId, InternetMessageId,
    SenderFromAddress, SenderFromDomain,
    SenderMailFromAddress, SenderMailFromDomain,
    SenderIPv4, RecipientEmailAddress, Subject,
    DeliveryAction, DeliveryLocation, ThreatTypes,
    DetectionMethods, ConfidenceLevel, EmailClusterId
| sort by Timestamp desc
```

THRESHOLD	WINDOW	JOIN	KEY	STATUS
None	30 days	None	P2 + P1 domains	Untested



TRIAGE & INVESTIGATION

Convert a sender-pattern match into defensible evidence.

WORKFLOW

1

Validate both layers

Preserve exact P2 header and P1 envelope addresses and domains.

2

Review delivery

Inspect action, location, verdicts, detections and recipient exposure.

3

Acquire content

Use approved mail investigation tools to retrieve raw MIME or HTML.

4

Inspect Unicode

Confirm Tags block code points inside visible finance text.

5

Scope infrastructure

Pivot by message IDs, sender IP, cluster and URLs without treating shared services as malicious.

Escalate

Both sender patterns, confirmed tag characters, finance lure and corroborating threat signals.

Benign context

Verified financial sender or approved campaign using a known marketing service.

Inconclusive

Pattern match without retrievable content or trustworthy sender context.

Do not overreach

activehosted.com, acemlnd.com and 173.236.20.0/24 are shared legitimate infrastructure and must not trigger alone.



FALSE POSITIVES & VALIDATION

Promotion gates for operational deployment.

QUALITY CONTROL

SCENARIO	OVERLAP	DISPOSITION
Financial marketing	M	Verify sender ownership and campaign history
Shared email platform	H	Never block on platform domain or IP alone
Security simulation	M	Scope approved sender and test window
Both patterns + tag content	H	Escalate for phishing investigation

Validation steps

1. Confirm both sender-domain fields are populated and semantically distinct.
2. Run the source query over available retention.
3. Collect raw MIME for representative matches.
4. Disposition all matches before adding exclusions.

Decision criteria

Success: known or controlled samples satisfy both patterns and benign matches are explainable.

Rejection: ordinary mail creates broad, inseparable overlap.

Failure: P1/P2 fields are absent, conflated or truncated.

Tuning

Allowlist only verified sender identities or documented campaigns. Do not add verdict, rarity or count thresholds without local evidence.



CONCLUSION & REFERENCES

Coverage statement, cross-platform limits and document control.

FINAL

CONCLUSION

A useful campaign hunt, not an ASCII-smuggling content detector.

The Microsoft-provided fingerprint and documented EmailEvents fields justify testing. Historical timing, mutable infrastructure and body invisibility prevent production classification.

Cross-SIEM decision

Splunk: no reliable SPL without a verified email source, index, sourcetype and separate P1/P2 domain extractions.

Chronicle: no reliable YARA-L without a verified mail parser and exact UDM mapping for both sender layers.

Deferred ideas

Body-level Unicode Tags detection, URL-join correlation, shared-platform domain alerts, IP-only rules, weekday-volume anomalies and Prompt Injection Protection as campaign proof.

References

- 1. Microsoft Security Research, 3 Sep 2026 - ASCII smuggling crosses over from AI prompt injection to phishing evasion.
microsoft[.]com/en-us/security/blog/2026/09/03/ascii-smuggling-crosses-over-from-ai-prompt-injection-to-phishing-evasion/
- 2. Microsoft Learn, updated 2 Sep 2026 - EmailEvents table.
learn[.]microsoft[.]com/en-us/defender-xdr/advanced-hunting-emailevents-table
- 3. MITRE ATT&CK - T1566 and T1027.
attack[.]mitre[.]org/techniques/T1566/ attack[.]mitre[.]org/techniques/T1027/

Document control

English dossier. No customer data. References defanged. HTML and rendering assets remain private and are excluded from publication.